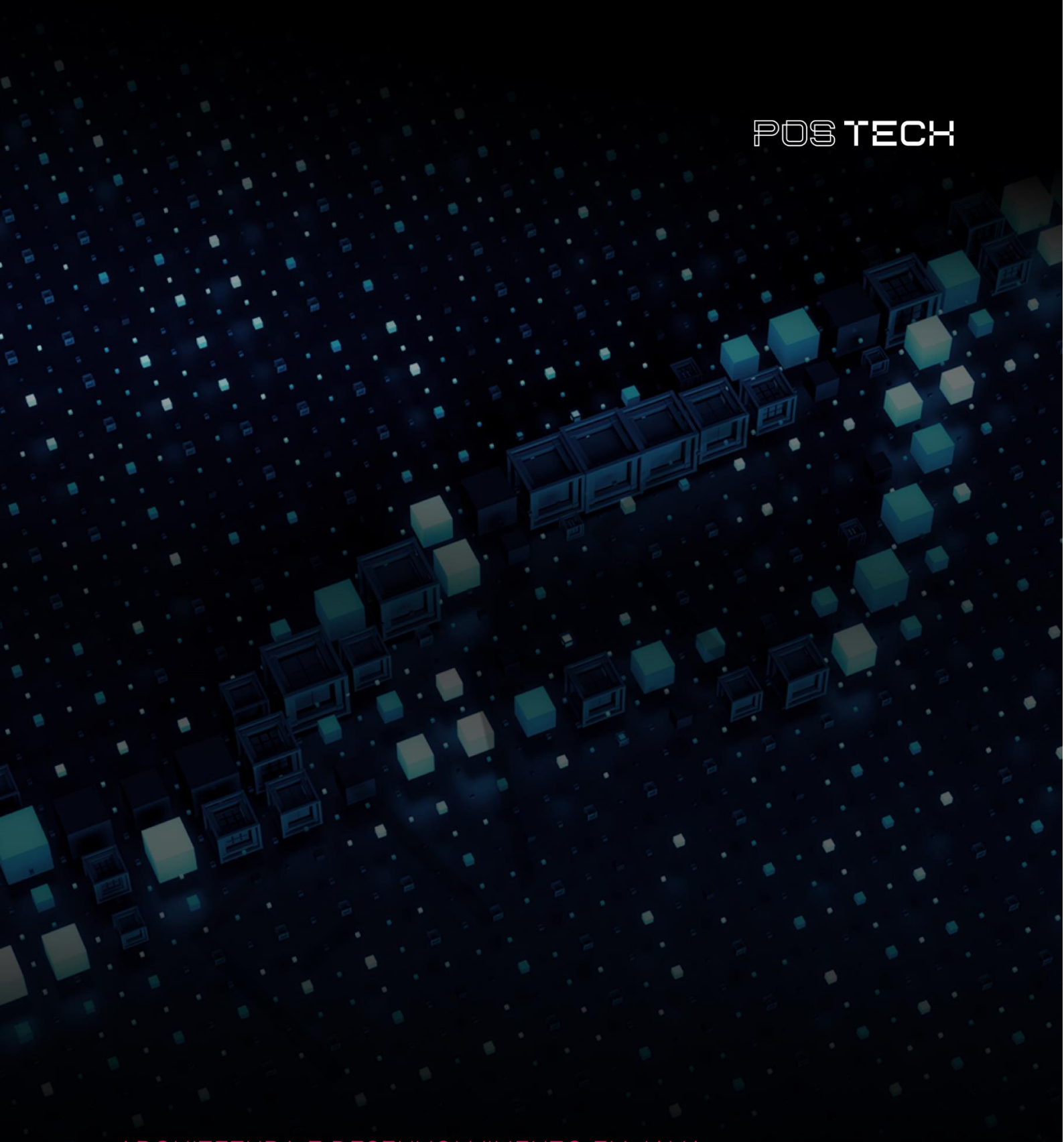


POS TECH

ARQUITETURA E DESENVOLVIMENTO EM JAVA

FASE 3 | AULA 04 -

CONFIGURANDO SPRING SECURITY

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

SUMÁRIO

O QUE VEM POR AÍ? 3
HANDS ON 4
SAIBA MAIS 5
O QUE VOCÊ VIU NESTA AULA? 9
REFERÊNCIAS 10
PALAVRAS-CHAVE 11

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

O QUE VEM POR AÍ?

Nessa aula, veremos configurações avançadas, customizações e extensões na segurança em aplicações Java com Spring Security. Vamos configurar o uso do Kong API Gateway em uma arquitetura de microsserviços e, em seguida, vamos implementar a autenticação mútua (mTLS - Mutual Transport Layer Security) que é a troca de certificados entre dois microsserviços chamados “Pessoa” e “Boleto” que se comunicam usando Feign Client.

Vamos configurar o Kong API Gateway para atuar como um reverse proxy e mTLS habilitado. Por fim, vamos utilizar o Spring Cloud Gateway para implementar o Access Token Pattern: um controle de acesso centralizado para garantir a segurança na comunicação entre os microsserviços.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

HANDS ON

Iniciaremos com a contextualização sobre o que é um API Gateway. Vamos então configurar os containers do Kong, as instâncias dos bancos de dados PostgreSQL, container do Konga e os serviços boleto-app e pessoa-app. Executaremos o docker-compose.yml para inicializar os serviços boleto-app e pessoa-app e o banco de dados PostgreSQL.

Vamos rodar as migrações do Kong e o Kong API Gateway. Acessaremos o painel de administração do Kong através do Konga para configurar os microsserviços no Kong API Gateway. Utilizaramos a IDE (Interfaces de Desenvolvimento Integrada) e o IntelliJ para codificar o projeto e mostrar toda a resolução e execução.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

SAIBA MAIS

Você sabe qual é uma **API Gateway**?

A API Gateway também é responsável por realizar processos de verificação de segurança, como autenticação e autorização. Então, tem muita coisa por trás de uma API gateway. Mais do que simplesmente um proxy reverso com o objetivo de rotear chamadas para diversos microsserviços, ela gera todo um ecossistema para que possa ser o portal de entrada da sua solução de software distribuído.

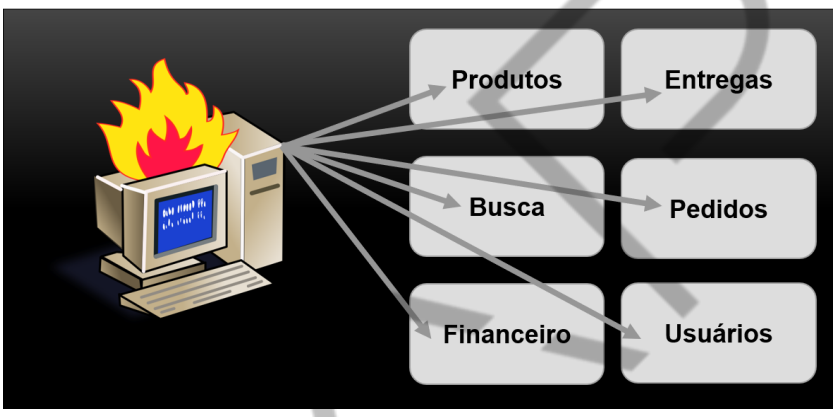


Figura 1 – Microsserviços
Fonte: elaborado pelo autor (2025)

Pensando na Figura 1, vamos imaginar que temos diversos microsserviços: **Produtos, Busca, Financeiro, Entregas, Pedidos e Usuários**. Cada serviço desse pode ser "deploiado" independentemente e não estamos falando aqui de um sistema monolítico, onde tudo está no mesmo sistema; estamos falando de microsserviços, onde cada um tem seu **IP**, seu **HOST**, sua **PORTA** e, principalmente, deve ter seu processo de validar autenticação. Mas imagine que:

- Para você utilizar o MS de **produtos**, acessa o IP A, o domínio B, etc.
- Para utilizar o MS de **Vendas**, agora é o IP C, o domínio D, etc.
- Para o MS do **Financeiro**, agora é outro IP X, etc.

É possível prever a confusão que aconteceria em uma aplicação **client** que vai consumir todos esses seis microsserviços e ficar batendo de forma espalhada. Sabemos, inclusive, que existem sistemas que possuem **milhares de**

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

microsserviços. Então, já podemos perceber que essa **dinâmica** fica impossível de ser organizada fazendo chamadas diretas, seria muito complicado de gerir.

Existem outros pontos importantes que devemos discutir, como de que forma realizaremos a autenticação de todos esses microsserviços e como trabalhar com **Basic Auth** ou com uma **API Token**, na qual passo um token que libera minha autenticação. Se quiser fazer a autenticação **Stateless**, posso trabalhar com JWT, que é o mais comum nos dias de hoje? Como trabalhar com autenticação utilizando o **LDAP**? Cada aplicação tem que ter um processo inteiro para realizar essas autenticações? Como utilizar **CORS** em nossas aplicações, que é algo extremamente importante para garantir a segurança e saber quem está fazendo requisições (**client**)?

Além disso, precisamos saber como determinar **políticas de tráfego**, determinando quem pode acessar um tipo de serviço ou quantas vezes alguém pode chamar esse serviço. Imagine, por exemplo, que um cliente A pode chamar minha API 10 vezes por segundo e um cliente B pode chamar minha API 10.000 vezes por segundo. Como configuro **Rate Limiting**? Se eu tenho uma forma de saber se o microsserviço foi chamado mais de 10 vezes por segundo, quero poder barrar a chamada, porque ele não tem mais essa permissão.

É preciso também pensar em **LOGs**, pois quero concentrar todas as minhas chamadas de logs em vez de deixá-las espalhadas, o que é muito comum. Nessa chamada inicial, poderíamos tratar esses **requisitos transversais** aqui.

Como monitorar o acesso a APIs?

Existem diversos motivos para fazer essa monitoração.



PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

Figura 2 – Associação entre API Gateway e serviços
Fonte: elaborado pelo autor (2025)

Na figura 2 temos uma associação entre um **ecossistema de microsserviços** com um **condomínio de casas luxuosas**. Pense que qualquer pessoa, que não seja o dono do imóvel e que deseja entrar no condomínio e visitar alguma casa, deve passar pela portaria. Para ter acesso liberado, é preciso passar pelo **portão**.

Por isso a nossa “portaria” é chamada de **GATE** (**API Gateway**). Todas as nossas requisições, independentemente de qual microsserviço seja acessado, vai passar pela **API gateway**, que vai reencaminhar essa requisição para o microsserviço desejado.

Nesse caso, quando a requisição bate na **API Gateway**, ela pode tratar essa requisição antes mesmo de chegar ao microsserviço. Por exemplo, vamos imaginar que eu mando uma requisição e o sistema de **Entregas** precisa estar autenticado, mas não quero gastar esforço no serviço se o usuário não estiver autenticado. Então, eu antecipo a autenticação na **API Gateway** e, se o usuário não estiver autenticado, ele nem chega até o microsserviço de **Entregas**.

Temos diversos mecanismos e soluções para conseguir trabalhar com **API Gateway**. Na figura 3, temos a **Amazon API Gateway**. Repare na quantidade de coisas que podemos fazer com ela.

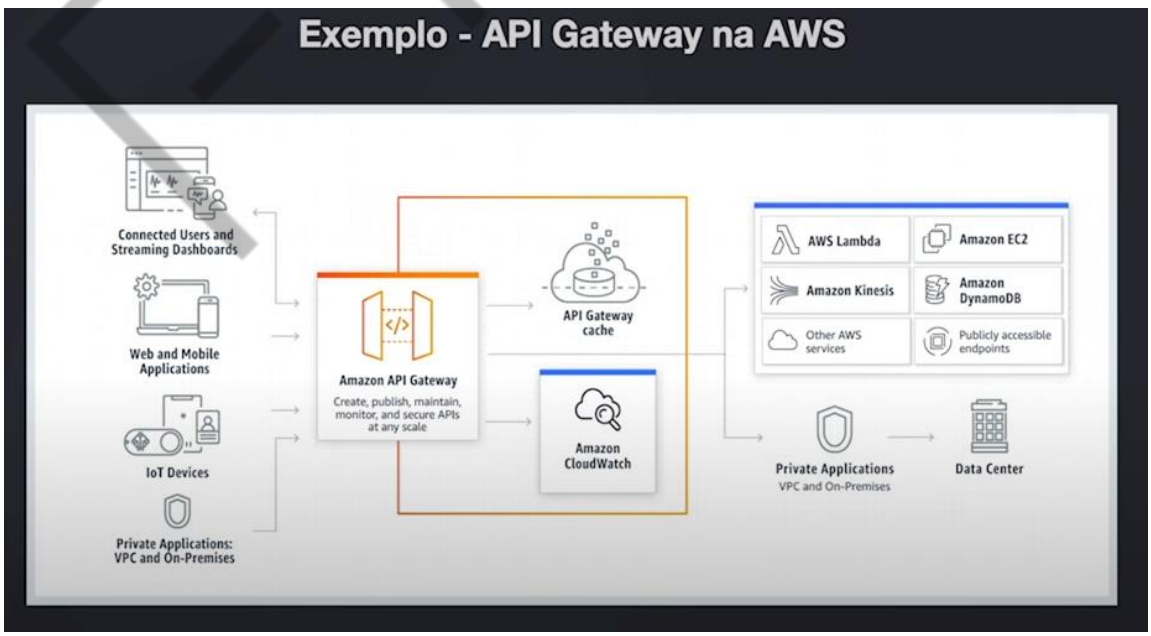


Figura 3 – Associação entre API Gateway e serviços
Fonte: elaborado pelo autor (2025)

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

Na maioria das vezes, não queremos ter um **lock-in** tão grande, que equivale ao risco alto de aprisionamento forçado na nuvem de um provedor (**Cloud Provider**). Por conta disso, existem outras soluções que podemos utilizar, como **API Gateway**, que funcionará na sua aplicação.

Uma dessas soluções é o famoso **Kong**, que é uma solução para **API Gateway** com muitos recursos, com versões **gratuita** e **enterprise**. A versão gratuita libera a **API do Kong**, através da qual é possível criar tudo o que for necessário por uma **API Rest.** No entanto, muitas vezes precisamos de um painel, uma interface gráfica mais amigável, que utiliza esses serviços do **Kong** na **API Rest**.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

O QUE VOCÊ VIU NESTA AULA?

Discutimos o uso do Kong API Gateway e suas configurações. Vimos detalhes importantes para configuração dos projetos e finalizamos a aula com a implementação de um Gateway, utilizando o Spring Cloud Gateway para implementar o Access Token Pattern, que é um controle de acesso centralizado para garantir a segurança na comunicação entre os microsserviços.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

REFERÊNCIAS

BAELDUNG. **Guia do Baeldung**. Disponível em: https://www.baeldung.com/?s=spring%20security. Acesso em: 08 fev. 2025.

NARDONE, M; SCARIONI, C. **Pro Spring Security: Securing Spring Framework 6 and Boot 3-based Java Applications**. New York: Apress, 2023.

SPRING.IO. **Documentação do Spring Security**. Disponível em: https://spring.io/projects/spring-security. Acesso em: 08 fev. 2025.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

PALAVRAS-CHAVE

Palavras-chave: spring. security. apigateway. mtls.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com



PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com